

INFORME DE PENTESTING

Proyecto Final de Ciberseguridad - 4Geeks

João Paulo Medeiros

1. Introducción

Este informe presenta los resultados de la prueba de intrusión realizada sobre un servidor Debian Linux desplegado en un entorno controlado. El objetivo del pentesting fue identificar servicios expuestos, validar vulnerabilidades existentes, demostrar el impacto de las fallas encontradas y aplicar recomendaciones de corrección.

La prueba fue realizada desde una máquina Kali Linux contra una máquina Debian dentro de la misma red local.

2. Alcance de la Prueba

Máquina atacante

Sistema Operativo: Kali Linux — IP: 192.168.1.49

Máquina objetivo

Sistema Operativo: Debian Linux — IP: 192.168.1.48

Servicios analizados

FTP | SSH | HTTP | Apache | WordPress | MariaDB

3. Metodología

La metodología utilizada siguió un enfoque básico de pentesting:

1. Reconocimiento inicial de la máquina objetivo
2. Enumeración de puertos y servicios
3. Pruebas de autenticación en los servicios expuestos
4. Identificación de vulnerabilidades
5. Explotación controlada
6. Aplicación de correcciones
7. Validación de las correcciones

4. Reconocimiento Inicial

Se realizó una prueba de conectividad utilizando ping y posteriormente un escaneo de puertos con Nmap.

Comandos utilizados

```
ping 192.168.1.48
```

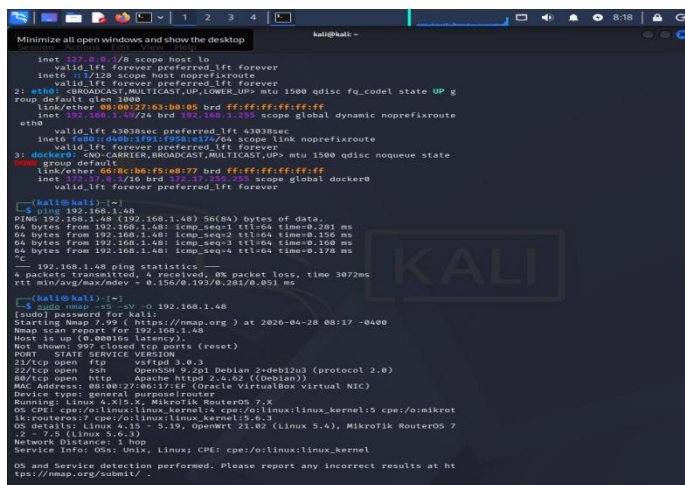
```
sudo nmap -sS -sV -O 192.168.1.48
```

Resultado

Se identificaron los siguientes puertos abiertos:

Puerto	Servicio	Versión
21	FTP	vsftpd 3.0.3
22	SSH	OpenSSH
80	HTTP	Apache2

Estos servicios fueron considerados como los principales puntos de análisis durante la prueba.



```
inset 192.168.1.0/24 scope host lo
valid_lft forever preferred_lft forever
inset 192.168.1.0/24 scope host noprefixroute
valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
link/ether 08:00:27:00:00:00 brd ff:ff:ff:ff:ff:ff
inset 192.168.1.0/24 scope global dynamic noprefixroute
eth0
valid_lft 43038sec preferred_lft 43038sec
inset 192.168.1.0/24 scope link noprefixroute
valid_lft forever preferred_lft forever
3: docker0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state
DOWN group default
link/ether 02:00:0c:00:00:00 brd ff:ff:ff:ff:ff:ff
inset 172.17.0.0/16 scope global docker0
valid_lft forever preferred_lft forever

(hali@kali) ~$ ping 192.168.1.48
PING 192.168.1.48 (192.168.1.48) 56(64) bytes of data:
64 bytes from 192.168.1.48: icmp_seq=1 ttl=64 time=0.281 ms
64 bytes from 192.168.1.48: icmp_seq=2 ttl=64 time=0.156 ms
64 bytes from 192.168.1.48: icmp_seq=3 ttl=64 time=0.168 ms
64 bytes from 192.168.1.48: icmp_seq=4 ttl=64 time=0.178 ms
^C
--- 192.168.1.48 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3872ms
rtt min/avg/max/mdev = 0.156/0.193/0.281/0.051 ms

(hali@kali) ~$
(hali@kali) ~$ sudo nmap -sS -v -i 192.168.1.48
[sudo] password for hali:
Starting Nmap 7.99 ( https://nmap.org ) at 2020-04-28 08:17 -0400
Nmap scan report for 192.168.1.48
Host is up (0.00016s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
80/tcp    open  http     Apache/2.4.42 ((Debian))
MAC Address: 08:00:27:00:00:17 (Oracle VirtualBox virtual NIC)
Device type: general purpose router
Running: Linux 4.X|5.X, Mikrotik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.10, OpenWRT 21.02 (Linux 5.4), Mikrotik RouterOS 7
.2 - 7.5 (Linux 5.6.2)
Network Distance: 1 hop
Service Info: OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/.
```

5. Vulnerabilidad 1 — FTP con acceso anónimo habilitado

Descripción

Se identificó que el servicio FTP permitía la autenticación anónima utilizando el usuario *anonymous*. Este tipo de configuración permite que usuarios sin credenciales válidas accedan al servicio FTP. Aunque las restricciones de permisos eran limitadas, esta exposición incrementa la superficie de ataque del servidor.

Prueba realizada

ftp 192.168.1.48

Usuario: anonymous

Contraseña: anonymous

El inicio de sesión se realizó correctamente.

Evidencia

El servidor devolvió:

230 Login successful.

```
kali@kali:~$ sudo nmap -i-v -sV -p- 192.168.1.48
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-28 08:17 -0400
Nmap scan report for 192.168.1.48
Host is up (0.0000s latency).
Not shown: 997 closed tcp ports (reset)
Host: 192.168.1.48
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:08:17:4F (Oracle VMVirtualBox virtual NIC)
Device type: general purpose/router
Running: Linux 4.X|5.X; Mikrotik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:linux:4.X|5.X; Mikrotik RouterOS 7.X
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), Mikrotik RouterOS 7
2 - 7.5 (Linux 5.4-22)
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 27.56 seconds

kali@kali:~$ ftp 192.168.1.48
ftp>
kali@kali:~$ ftp 192.168.1.48
Connected to 192.168.1.48.
220 (vsftpd 3.0.3)
Name (192.168.1.48:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||37898|)
150 Here comes the directory listing.
226 Directory send OK.
ftp>
```

Enumeración FTP

Después del acceso, se ejecutaron comandos básicos para verificar el directorio disponible.

pwd

ls

ls -la

Fue posible listar el contenido del directorio remoto.

```
kali@kali:~$ sudo nmap -i-v -sV -p- 192.168.1.48
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-28 08:17 -0400
Nmap scan report for 192.168.1.48
Host is up (0.0000s latency).
Not shown: 997 closed tcp ports (reset)
Host: 192.168.1.48
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:08:17:4F (Oracle VMVirtualBox virtual NIC)
Device type: general purpose/router
Running: Linux 4.X|5.X; Mikrotik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:linux:4.X|5.X; Mikrotik RouterOS 7.X
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), Mikrotik RouterOS 7
2 - 7.5 (Linux 5.4-22)
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 27.56 seconds

kali@kali:~$ ftp 192.168.1.48
ftp>
kali@kali:~$ ftp 192.168.1.48
Connected to 192.168.1.48.
220 (vsftpd 3.0.3)
Name (192.168.1.48:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||37898|)
150 Here comes the directory listing.
226 Directory send OK.
ftp> pwd
Remote directory: /
ftp> ls -la
229 Entering Extended Passive Mode (|||56878|)
150 Here comes the directory listing.
drwxr-xr-x  2 0      122      4096 Oct 08 2024 .
drwxr-xr-x  2 0      122      4096 Oct 08 2024 ..
226 Directory send OK.
ftp>
```

Prueba de permisos de escritura

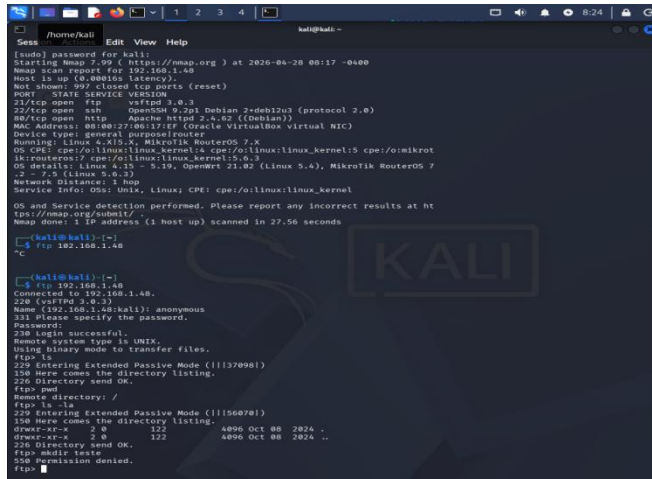
Se probó la posibilidad de crear un directorio.

mkdir teste

El servidor respondió:

550 Permission denied.

Esto indica que el usuario anónimo no poseía permisos de escritura.



```
kali@kali: ~  
[root] Password for kali:  
Starting Nmap 7.99 ( https://nmap.org ) at 2020-06-28 08:17 -0400  
Nmap scan request for 192.168.1.48  
Host is up (0.0001s latency).  
Not shown: 992 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
21/tcp open  ftp      vsftpd 3.0.3  
22/tcp open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)  
80/tcp open  http     Apache/2.4.42 ((Debian))  
MAC Address: 08:00:27:08:17:EF (Oracle VirtualBox virtual NIC)  
Device type: general purpose/router  
Running: Linux 4.X15.X, MikroTik RouterOS 7.x  
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7  
ikrouteros:7 cpe:/o:linux:linux_kernel:5.6.3  
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 3.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6-3)  
Network Distance: 0 hops  
Service Info: OSs: UNIX, Linux; CPE: cpe:/o:linux:linux_kernel  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/  
Nmap done: 1 IP address (1 host up) scanned in 27.56 seconds  
[kali@kali] ~  
[*] ftp: 192.168.1.48  
[*]  
[kali@kali] ~  
[*] ftp: 192.168.1.48  
Connected to 192.168.1.48.  
220 (vsftpd 3.0.3)  
Name (192.168.1.48:kali): anonymous  
331 please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||37898|)  
350 Here comes the directory listing.  
226 Directory send OK.  
ftp> pwd  
Remote directory: /  
ftp> ls -la  
229 Entering Extended Passive Mode (|||56078|)  
350 Here comes the directory listing.  
drwxr-xr-x  2 0      122      4096 Oct  8  2024 .  
drwxr-xr-x  2 0      122      4096 Oct  8  2024 ..  
226 Directory send OK.  
ftp> mkdir teste  
550 Permission denied.  
ftp>
```

Impacto

- Acceso no autorizado al servicio FTP
- Posibilidad de enumeración de directorios
- Incremento de la superficie de ataque
- Riesgo de exposición de archivos en caso de permisos incorrectos

Severidad

Media

La vulnerabilidad es relevante porque permite autenticación sin credenciales válidas, aunque no se detectaron permisos de escritura.

Corrección aplicada

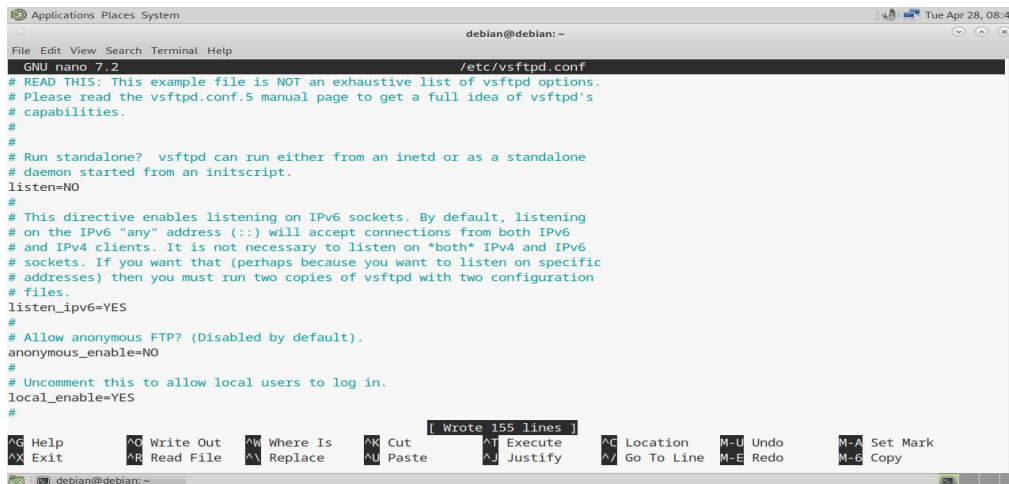
El archivo de configuración de vsftpd fue modificado:

/etc/vsftpd.conf

La configuración fue cambiada a:

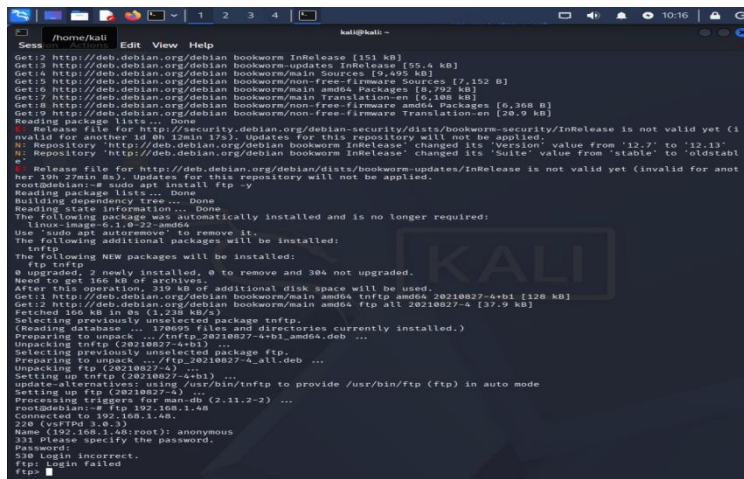
anonymous_enable=NO

Posteriormente, el servicio fue reiniciado.



Validación de corrección

Se realizó una nueva prueba de autenticación FTP utilizando el usuario anonymous. El acceso fue correctamente bloqueado.



6. Vulnerabilidad 2 — Login SSH remoto con el usuario root

Descripción

Se identificó que el servidor permitía la autenticación remota vía SSH utilizando directamente el usuario root. Esta configuración es considerada insegura, ya que el usuario root tiene privilegios administrativos completos sobre el sistema. En caso de contraseña débil o comprometida, un atacante podría obtener control total del servidor.

Prueba realizada

```
ssh root@192.168.1.48
```

Fue posible autenticarse utilizando la cuenta root con una credencial débil configurada en el entorno de laboratorio.

Evidencia

Después de la autenticación se obtuvo acceso administrativo:

```
root@debian:~#
```

```
kali@kali: ~  
Session Actions Edit View Help  
[~] kali@kali:~  
[~] # ssh 192.168.1.48  
Connected to 192.168.1.48.  
228 (vrfing 3.0-2)  
Name (192.168.1.48:kali): anonymous  
331 Please specify the password.  
Password:  
238 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
209 ls  
229 Entering Extended Passive Mode (|||37090|)  
150 Here comes the directory listing.  
226 Directory send OK.  
ls  
Remote directory: /  
209 ls  
229 Entering Extended Passive Mode (|||56070|)  
150 Here comes the directory listing.  
drwxr-xr-x  2 0      122      4096 Oct 08 2024 .  
drwxr-xr-x  2 0      122      4096 Oct 08 2024 ..  
226 Directory send OK.  
ftp: md5dir test  
150 Permission denied.  
ftp: bye  
221 Goodbye.  
[~] kali@kali:~  
[~] # ssh root@192.168.1.48  
The authenticity of host '192.168.1.48 (192.168.1.48)' can't be established.  
ED25519 key fingerprint is: SHA256:yvazUu5Jk3Wv8tEjMaT8wYbWwH78LCT7p3rvig  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '192.168.1.48' (ED25519) to the list of known hosts.  
root@192.168.1.48's password:  
Permission denied, please try again.  
root@192.168.1.48's password:  
Linux debian 6.1.0-25-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.106-3 (2024-08-26) x86_64  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/*copyright.  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
root@debian:~# whoami  
root  
root@debian:~# pwd  
/root  
root@debian:~# cat /etc/ssh/sshd_config | grep -i permitrootlogin  
PermitRootLogin yes  
# the setting of "PermitRootLogin prohibit-password".  
root@debian:~#
```

Validación de privilegios

Se ejecutaron comandos básicos para confirmar los privilegios administrativos.

```
whoami
```

```
pwd
```

Resultado:

```
root
```

```
/root
```

Verificación de la configuración

Se verificó el archivo de configuración del servicio SSH:

```
cat /etc/ssh/sshd_config | grep -i permitrootlogin
```

Resultado identificado:

PermitRootLogin yes

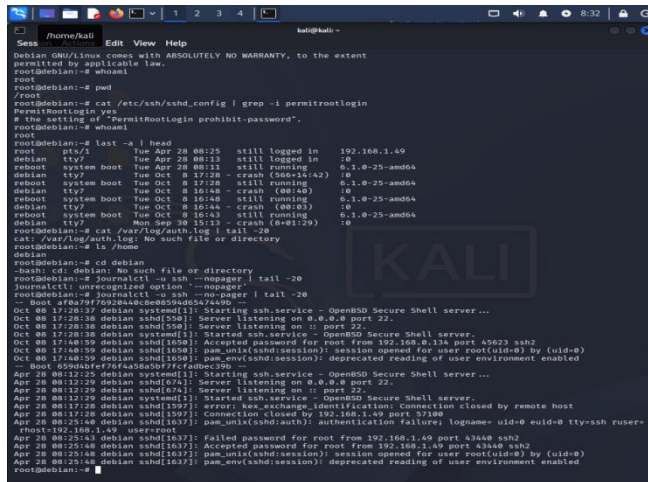
```
kali@kali: ~  
Session Actions Edit View Help  
[~] kali@kali:~  
[~] # ssh 192.168.1.48  
Connected to 192.168.1.48.  
228 (vrfing 3.0-2)  
Name (192.168.1.48:kali): anonymous  
331 Please specify the password.  
Password:  
238 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
209 ls  
229 Entering Extended Passive Mode (|||37090|)  
150 Here comes the directory listing.  
drwxr-xr-x  2 0      122      4096 Oct 08 2024 .  
drwxr-xr-x  2 0      122      4096 Oct 08 2024 ..  
226 Directory send OK.  
ftp: md5dir test  
150 Permission denied.  
ftp: bye  
221 Goodbye.  
[~] kali@kali:~  
[~] # ssh root@192.168.1.48  
The authenticity of host '192.168.1.48 (192.168.1.48)' can't be established.  
ED25519 key fingerprint is: SHA256:yvazUu5Jk3Wv8tEjMaT8wYbWwH78LCT7p3rvig  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '192.168.1.48' (ED25519) to the list of known hosts.  
root@192.168.1.48's password:  
Permission denied, please try again.  
root@192.168.1.48's password:  
Linux debian 6.1.0-25-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.106-3 (2024-08-26) x86_64  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/*copyright.  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
root@debian:~# whoami  
root  
root@debian:~# pwd  
/root  
root@debian:~# cat /etc/ssh/sshd_config | grep -i permitrootlogin  
PermitRootLogin yes  
# the setting of "PermitRootLogin prohibit-password".  
root@debian:~# whoami  
root  
root@debian:~# last -a | head  
root    pts/1          Tue Apr 28 08:25      still logged in      192.168.1.49  
debian  tty7           Tue Apr 28 08:13      still logged in      :0  
reboot  system boot    Tue Apr 28 08:11      still running        6.1.0-25-amd64  
debian  tty7           Tue Oct 8 17:28      crash (566-14-42)    :0  
reboot  system boot    Tue Oct 8 17:28      still running        6.1.0-25-amd64  
debian  tty7           Tue Oct 8 16:48      crash (80:48)        :0  
reboot  system boot    Tue Oct 8 16:48      still running        6.1.0-25-amd64  
debian  tty7           Tue Oct 8 16:44      crash (80:03)        :0  
reboot  system boot    Tue Oct 8 16:43      still running        6.1.0-25-amd64  
debian  tty7           Mon Sep 30 15:13      crash (8+0:29)       :0  
root@debian:~# cat /var/log/auth.log | tail -20  
cat: /var/log/auth.log: No such file or directory  
root@debian:~# ls /home  
debian  
root@debian:~#
```

Análisis de logs

Se analizaron eventos relacionados con el servicio SSH:

```
journalctl -u ssh --no-pager | tail -20
```

Los logs registraron intentos de autenticación y sesiones abiertas para el usuario root.



```
root@kali:~# journalctl -u ssh --no-pager | tail -20
-- Root 4f687f7025a4ac8eb056d4247450
Oct 08 17:28:37 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server...
Oct 08 17:28:38 debian sshd[550]: Server listening on 0.0.0.0 port 22.
Oct 08 17:28:38 debian sshd[550]: Server listening on :: port 22.
Oct 08 17:28:38 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134 port 45623 ssh2
Oct 08 17:40:59 debian sshd[1650]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
Oct 08 17:40:59 debian sshd[1650]: pam_env(sshd:session): deprecated reading of user environment enabled
-- Root 050d40e77445b5077efdb0c305
Apr 28 08:12:25 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server...
Apr 28 08:12:29 debian sshd[674]: Server listening on 0.0.0.0 port 22.
Apr 28 08:12:29 debian sshd[674]: Server listening on :: port 22.
Apr 28 08:12:29 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
Apr 28 08:17:28 debian sshd[1597]: error: kex_exchange_identification: Connection closed by remote host
Apr 28 08:17:28 debian sshd[1597]: Connection closed by 192.168.1.49 port 77100
Apr 28 08:25:48 debian sshd[1637]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser=
root@kali:~#
```

Impacto

- Control total del servidor
- Posibilidad de modificar archivos del sistema
- Creación o eliminación de usuarios
- Alteración de servicios críticos
- Riesgo de persistencia maliciosa
- Posibilidad de eliminación de evidencias y logs

Severidad

Crítica

La vulnerabilidad permite el acceso administrativo remoto directo.

Corrección aplicada

El archivo `/etc/ssh/sshd_config` fue modificado. La configuración fue cambiada a:

```
PermitRootLogin no
```



```
Applications Places System
debian@debian:~$ nano /etc/ssh/sshd_config

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.

Help Write Out Where Is Cut Execute Location Undo Set Mark
Exit Read File Replace Paste Justify Go To Line Redo Redo Copy
```

Validación de la corrección

Se realizó una nueva prueba de acceso remoto:

ssh root@192.168.1.48

El servidor bloqueó correctamente la autenticación.

```
kali@kali:~$ ssh root@192.168.1.48
root@debian:~$ whoami
root
root@debian:~$ last -a | head
root    pts/0    Tue Apr 28 08:25   still logged in   192.168.1.49
root    pts/0    Tue Apr 28 08:13   still logged in   :0
debian  tty7     Tue Apr 28 08:13   still logged in   :0
reboot  system boot Tue Apr 28 08:11   still running     6.1.0-25-amd64
debian  tty7     Tue Oct 8 17:28   crash (Sched:1:42) :0
reboot  system boot Tue Oct 8 17:28   still running     6.1.0-25-amd64
debian  tty7     Tue Oct 8 16:48   still running     6.1.0-25-amd64
reboot  system boot Tue Oct 8 16:48   still running     6.1.0-25-amd64
debian  tty7     Tue Oct 8 16:44   crash (00:43) :0
reboot  system boot Tue Oct 8 16:43   still running     6.1.0-25-amd64
debian  tty7     Mon Sep 30 15:13   crash (8+0:29) :0
root@debian:~$ cat /var/log/auth.log | tail -20
cat: /var/log/auth.log: No such file or directory
root@debian:~$ ls /home
debian
root@debian:~$ cd debian
-bash: cd: debian: No such file or directory
root@debian:~$ journalctl -u ssh --noPager | tail -20
journalctl: unrecognized option '--noPager'
root@debian:~$ journalctl -u ssh --noPager | tail -20
-- Boot 2f8a79f76928440c8eb8594d0347449b --
Oct 08 17:28:17 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server ...
Oct 08 17:28:38 debian sshd[550]: Server listening on 0.0.0.0 port 22.
Oct 08 17:28:38 debian sshd[550]: Server listening on :: port 22.
Oct 08 17:28:38 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134 port 42623 ssh2
Oct 08 17:40:59 debian sshd[1650]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
Oct 08 17:40:59 debian sshd[1650]: pam_env(sshd:session): deprecated reading of user environment enabled
-- Boot 65904b4ref7644a58a3b97fcdadec39b --
Apr 28 08:12:25 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server ...
Apr 28 08:12:29 debian sshd[674]: Server listening on 0.0.0.0 port 22.
Apr 28 08:12:29 debian sshd[674]: Server listening on :: port 22.
Apr 28 08:12:29 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
Apr 28 08:17:28 debian sshd[1597]: error: kex_exchange_identification: Connection closed by remote host
Apr 28 08:17:28 debian sshd[1597]: Connection closed by 192.168.1.49 port 57100
Apr 28 08:25:40 debian sshd[1637]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser=
rhost=192.168.1.48 user=root
Apr 28 08:25:43 debian sshd[1637]: Failed password for root from 192.168.1.49 port 43440 ssh2
Apr 28 08:25:48 debian sshd[1637]: Accepted password for root from 192.168.1.49 port 42440 ssh2
Apr 28 08:25:48 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
Apr 28 08:25:48 debian sshd[1637]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
Apr 28 08:25:48 debian sshd[1637]: pam_env(sshd:session): deprecated reading of user environment enabled
root@debian:~$ ssh root@192.168.1.48
The authenticity of host '192.168.1.48 (192.168.1.48)' can't be established.
ED25519 key fingerprint is SHA256:Yy4xU063Jk2M0v4E3Mat54MybvwH7xBL7p2zuLg.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.48' (ED25519) to the list of known hosts.
root@192.168.1.48's password:
Permission denied, please try again.
root@192.168.1.48's password: 
```


7. Vulnerabilidad 3 — WordPress configurado incorrectamente con localhost

Descripción

Durante la enumeración web se identificó que el servidor ejecutaba WordPress. La aplicación presentaba un comportamiento incorrecto: al acceder al panel administrativo mediante la IP del servidor, WordPress redireccionaba hacia localhost. Esto indicaba un error de configuración en los parámetros internos de la aplicación.

Enumeración web

Se utilizó Gobuster para identificar directorios web.

```
gobuster dir -u http://192.168.1.48 -w /usr/share/wordlists/dirb/common.txt
```

Se encontraron directorios como:

```
/wp-admin  
/wp-content  
/wp-includes  
/wp-login.php
```

Análisis de configuración en la base de datos

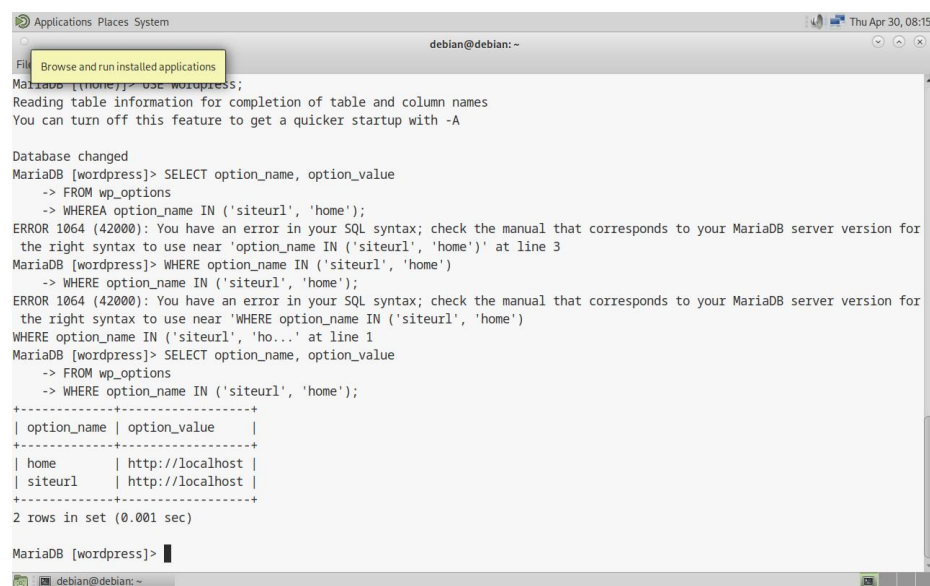
Se accedió a MariaDB y se consultó la tabla de configuración de WordPress.

USE wordpress;

```
SELECT option_name, option_value FROM wp_options WHERE option_name IN ('siteurl', 'home');
```

Resultado identificado:

```
home | http://localhost  
siteurl | http://localhost
```



```
Applications Places System  
debian@debian: ~  
File Edit View Window Help  
Browse and run installed applications  
MariaDB [(none)]> USE wordpress;  
Reading table information for completion of table and column names  
You can turn off this feature to get a quicker startup with -A  
  
Database changed  
MariaDB [(wordpress)]> SELECT option_name, option_value  
-> FROM wp_options  
-> WHERE option_name IN ('siteurl', 'home');  
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for  
the right syntax to use near 'option_name IN ('siteurl', 'home')' at line 3  
MariaDB [(wordpress)]> WHERE option_name IN ('siteurl', 'home')  
-> WHERE option_name IN ('siteurl', 'home');  
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for  
the right syntax to use near 'WHERE option_name IN ('siteurl', 'home')' at line 1  
MariaDB [(wordpress)]> SELECT option_name, option_value  
-> FROM wp_options  
-> WHERE option_name IN ('siteurl', 'home');  
+-----+-----+  
| option_name | option_value |  
+-----+-----+  
| home       | http://localhost |  
| siteurl    | http://localhost |  
+-----+-----+  
2 rows in set (0.001 sec)  
  
MariaDB [(wordpress)]>
```

Impacto

- Redireccionamiento inválido
- Fallo de acceso remoto al panel WordPress
- Indisponibilidad parcial de la aplicación
- Dificultad de administración remota
- Funcionamiento incorrecto del sitio web

Severidad

Media

La vulnerabilidad no otorgaba acceso administrativo directo, pero afectaba la disponibilidad y funcionamiento correcto de la aplicación.

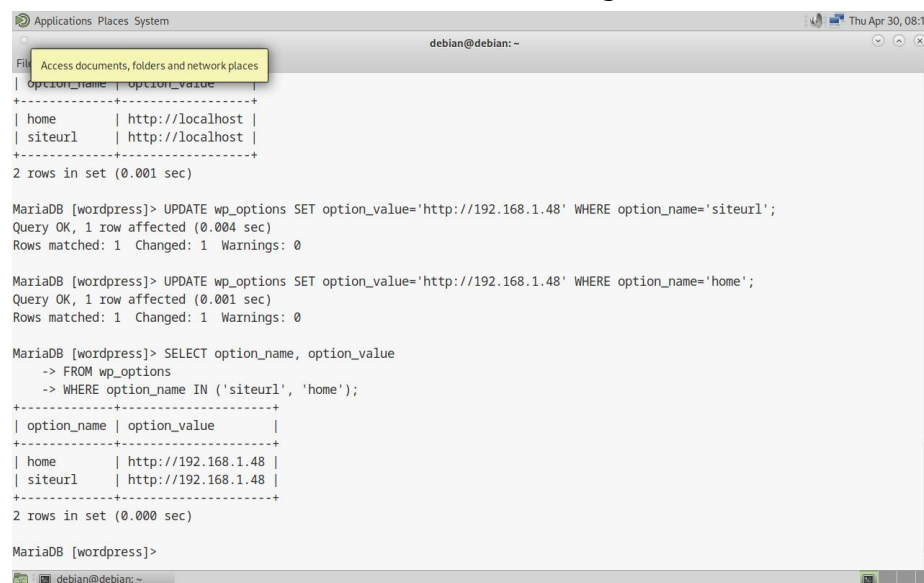
Corrección aplicada

Los valores siteurl y home fueron corregidos directamente en la base de datos.

```
UPDATE wp_options SET option_value='http://192.168.1.48' WHERE option_name='siteurl';
```

```
UPDATE wp_options SET option_value='http://192.168.1.48' WHERE option_name='home';
```

Posteriormente se validó nuevamente la configuración.



The screenshot shows a terminal window with the following content:

```
Applications Places System
Access documents, folders and network places
option_name | option_value
+-----+-----+
| home      | http://localhost |
| siteurl   | http://localhost |
+-----+-----+
2 rows in set (0.001 sec)

MariaDB [wordpress]> UPDATE wp_options SET option_value='http://192.168.1.48' WHERE option_name='siteurl';
Query OK, 1 row affected (0.004 sec)
Rows matched: 1  Changed: 1  Warnings: 0

MariaDB [wordpress]> UPDATE wp_options SET option_value='http://192.168.1.48' WHERE option_name='home';
Query OK, 1 row affected (0.001 sec)
Rows matched: 1  Changed: 1  Warnings: 0

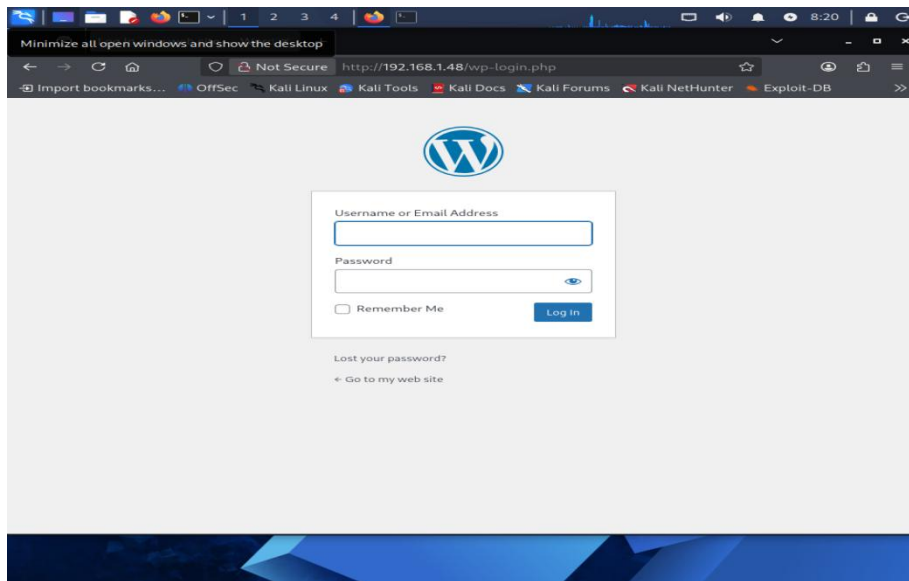
MariaDB [wordpress]> SELECT option_name, option_value
-> FROM wp_options
-> WHERE option_name IN ('siteurl', 'home');
+-----+-----+
| option_name | option_value |
+-----+-----+
| home       | http://192.168.1.48 |
| siteurl    | http://192.168.1.48 |
+-----+-----+
2 rows in set (0.000 sec)

MariaDB [wordpress]>
```

Validación de la corrección

Después de la modificación, el panel WordPress fue accesible correctamente desde el navegador utilizando la IP del servidor.

<http://192.168.1.48/wp-login.php>



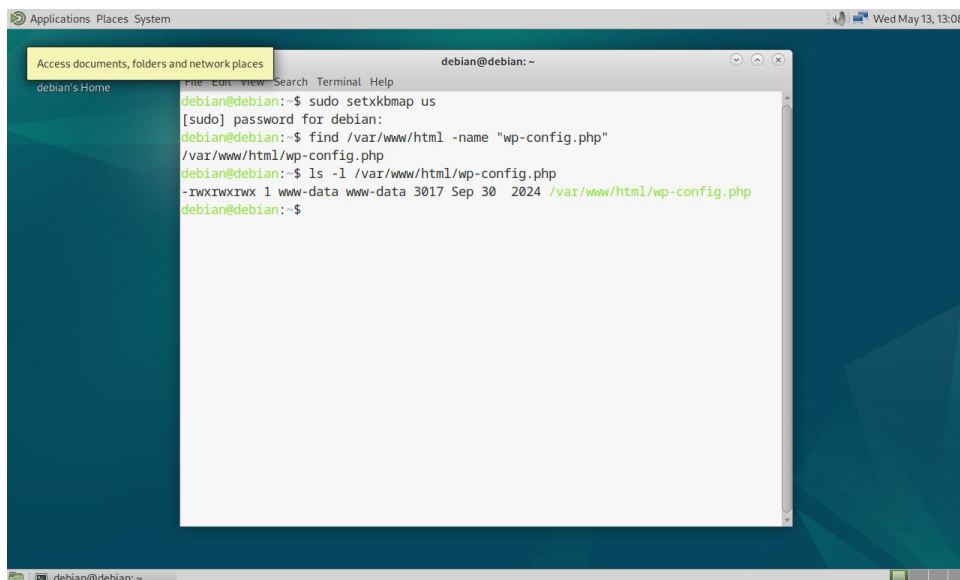
8. Vulnerabilidad 4 — Permisos inseguros en wp-config.php

Descripción

Durante la revisión de seguridad del entorno WordPress, también se identificó que el archivo wp-config.php presentaba permisos excesivamente permisivos (777), permitiendo lectura, escritura y ejecución para todos los usuarios del sistema.

Configuración identificada inicialmente:

```
-rwxrwxrwx
```



Impacto

- Exposición de credenciales de la base de datos
- Posibilidad de lectura del archivo por cualquier usuario del sistema
- Riesgo de modificación del archivo de configuración
- Compromiso potencial de la base de datos WordPress

Severidad

Media

La vulnerabilidad requiere acceso local al sistema para ser explotada, pero expone credenciales críticas de la aplicación.

Corrección aplicada

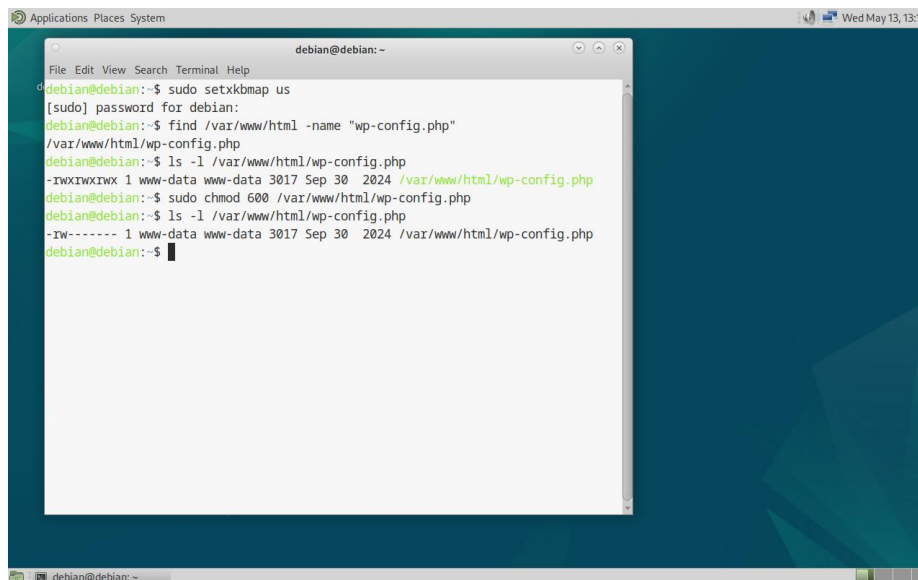
Como medida correctiva, los permisos fueron restringidos utilizando:

```
sudo chmod 600 /var/www/html/wp-config.php
```

Posteriormente, se verificó nuevamente la configuración del archivo.

Resultado final:

```
-rw-----
```

A screenshot of a Linux terminal window titled 'debian@debian: ~'. The terminal shows the following commands and output: 1. 'sudo setxkbmap us' is executed. 2. '[sudo] password for debian:' is prompted. 3. 'find /var/www/html -name "wp-config.php"' is executed, returning '/var/www/html/wp-config.php'. 4. 'ls -l /var/www/html/wp-config.php' is executed, showing '-IWXIXIXIX 1 www-data www-data 3017 Sep 30 2024 /var/www/html/wp-config.php'. 5. 'sudo chmod 600 /var/www/html/wp-config.php' is executed. 6. 'ls -l /var/www/html/wp-config.php' is executed, showing '-rw----- 1 www-data www-data 3017 Sep 30 2024 /var/www/html/wp-config.php'. The terminal window is part of a desktop environment with a dark blue background and a top bar showing 'Applications Places System' and the date 'Wed May 13, 13:10'.

La corrección aplicada garantiza que únicamente el propietario del archivo pueda leer y modificar el contenido

9. Resumen de Vulnerabilidades Encontradas

ID	Vulnerabilidad	Servicio	Severidad	Estado
VULN-01	FTP con acceso anonymous habilitado	FTP	Media	Corregida
VULN-02	Login root vía SSH permitido	SSH	Crítica	Corregida
VULN-03	WordPress configurado con localhost	HTTP/WordPress	Media	Corregida
VULN -04	Permisos inseguros en wp-config.php	Wordpress/Sistema	Media	Corregida

10. Recomendaciones Generales

8. Deshabilitar autenticación anónima en los servicios FTP
9. Evitar exposición innecesaria del servicio FTP
10. Desabilitar login remoto directo con root
11. Utilizar usuarios con privilegios limitados
12. Implementar contraseñas robustas
13. Preferir autenticación SSH mediante clave pública
14. Monitorear logs de autenticación
15. Revisar configuraciones de las aplicaciones web
16. Mantener servicios y paquetes actualizados
17. Aplicar hardening básico en los servidores Linux

11. Conclusión

La prueba de intrusión permitió identificar vulnerabilidades importantes en el servidor Debian analizado. Las fallas más relevantes estaban relacionadas con configuraciones inseguras en servicios expuestos, especialmente FTP y SSH. También se identificó una configuración incorrecta en WordPress que afectaba el funcionamiento de la aplicación vía red.

Todas las vulnerabilidades explotadas fueron corregidas y posteriormente validadas mediante nuevas pruebas. El proceso demostró la importancia de realizar reconocimiento, validación, corrección y retesting dentro de un ciclo completo de seguridad.